J&J ACELERAÇÃO CYBERSECURITY

IDENTITY AND ACCESS MANAGEMENT (IAM)

Federação e SSO

Material didático do aluno

Objetivo de aprendizagem: **Entender federação de identidade e SSO.**

Nível básico/intermediário
Conceitos, fluxos, exemplos corporativos e atividades

Nome: _____

Turma: _____ Data: _____

Edição de estudo | 22 de outubro de 2026

Os cenários empresariais são fictícios e foram criados para aprendizagem. Não descrevem a arquitetura nem as políticas internas da J&J.

ORIENTAÇÃO DE ESTUDO

Como usar este material

Você estudará como um sistema pode aceitar a autenticação realizada por outro e como essa confiança permite acessar vários serviços com menos solicitações de login. O foco é compreender decisões de arquitetura e segurança antes de configurar produtos.

Ao concluir, você deverá conseguir

1. Diferenciar identidade local, federação, SSO e autorização.
2. Identificar os participantes de um login federado.
3. Comparar SAML, OIDC e OAuth 2.0 sem confundir suas finalidades.
4. Explicar riscos, sessões e ciclo de vida de acesso.
5. Desenhar e justificar uma arquitetura federada simples.

Percurso	Páginas
Fundamentos: conceitos, identidades e participantes	3-5
Confiança e fluxos: visão geral, SAML, OIDC e OAuth	6-10
Comparação, tokens e exemplos de plataformas	11-13
Proteção, provisionamento, ciclo de vida e sessões	14-17
Riscos, operação, logs e auditoria	18-19
Estudo de caso, investigação e desafio final	20-22
Exercícios, autoavaliação e glossário	23-25
Referências e leituras complementares	26-27

Modo de estudo: leia em sequência, acompanhe as setas dos diagramas e faça as microtarefas. Registre respostas no caderno ou em um documento. As atividades não exigem uma conta paga nem mudanças em sistemas reais.

As indicações [1], [2] etc. remetem às referências das páginas 26 e 27. Fluxos são simplificações didáticas; uma implantação requer bibliotecas confiáveis e validações completas.

01 | FUNDAMENTOS

Quatro conceitos que se conectam

Autenticação verifica se a pessoa controla os autenticadores associados à identidade apresentada. Senha, chave de segurança e passkey são exemplos de meios usados nessa verificação. Estar autenticado não significa poder executar qualquer operação.

Autorização decide quais recursos e ações uma identidade pode acessar. Uma pessoa pode entrar no sistema de RH e consultar seu holerite, mas não alterar a remuneração de colegas.

Federação de identidade permite que uma aplicação confie em informações de autenticação emitidas por um provedor de identidade de outro domínio de segurança. Essa confiança depende de acordos e verificações técnicas. [1]

Single Sign-On (SSO), ou login único, é a experiência de autenticar-se uma vez e acessar vários serviços sem repetir a autenticação completa enquanto a sessão e as políticas permitirem. A federação é uma forma comum de viabilizá-la.

Analogia: recepção de um centro empresarial

A recepção verifica sua identidade e emite uma credencial. Cada empresa decide se aceita essa credencial e quais salas você pode visitar. A verificação representa autenticação; a aceitação entre organizações ilustra federação; o acesso às salas representa autorização.

SSO não garante acesso irrestrito nem ausência de novas verificações. Uma ação sensível pode exigir MFA adicional ou autenticação recente. Também existe SSO dentro de um domínio, sem federação entre domínios separados.

Microtarefa 1

Uma pessoa entra no RH, mas recebe “acesso negado” ao abrir a folha salarial da equipe. Qual decisão funcionou e qual decisão restringiu a ação? Explique a diferença.

02 | IDENTIDADES E EXPERIÊNCIA

Identidade local, federada e SSO

Aspecto	Identidade local	Identidade federada
Quem autentica?	A própria aplicação ou seu serviço local.	Um IdP aceito pela aplicação.
Credencial da pessoa	É verificada no ambiente da aplicação.	É verificada pelo IdP; não precisa ser compartilhada com cada aplicativo.
Registro na aplicação	Conta e permissões locais.	Pode continuar existindo como perfil, vínculo e permissões.
Ciclo de vida	Pode exigir ação em cada sistema.	Pode ser integrado; depende de provisionamento e controles próprios.

Mesmo login e senha não comprovam SSO. Se Ana digita as mesmas credenciais separadamente no portal, no RH e no treinamento, pode haver três autenticações independentes. Repetir uma senha em bases distintas ainda aumenta a exposição a vazamentos.

SSO real: Ana entra no portal. Ao abrir o treinamento, o serviço consulta o IdP pelo fluxo federado; uma sessão válida no IdP permite concluir o processo sem pedir novamente a senha. Cada aplicação pode criar sua própria sessão.

Sincronização de senha replica ou alinha credenciais entre ambientes. **Federação** troca mensagens de confiança. **Provisionamento** cria ou atualiza contas. Essas capacidades podem coexistir, mas cumprem funções diferentes.

Microtarefa 2

Compare dois cenários: (A) repetir a senha em três telas; (B) acessar três aplicações após autenticar-se no IdP. Que evidência você buscaria para confirmar SSO? Não use apenas a igualdade do endereço de e-mail como prova.

03 | PARTICIPANTES

Quem faz o quê no login federado?

Participante	Responsabilidade e exemplo
Usuário	Pessoa que solicita acesso. Exemplo: Ana, analista de operações.
Navegador / user agent	Segue redirecionamentos, transporta mensagens previstas no protocolo e mantém cookies de sessão por domínio.
IdP / OpenID Provider	Autentica a pessoa, aplica políticas e emite informações verificáveis. Em OIDC, o IdP também é chamado de OP.
SP / Relying Party	Aplicação que aceita a autenticação externa. Em SAML, é o Service Provider (SP); em OIDC, é a Relying Party (RP), também cliente OIDC.
API / resource server	Serviço que aceita access tokens para operações autorizadas. É um papel adicional no cenário OAuth. [5]

Exemplo corporativo: no acesso ao treinamento, Ana é a usuária; seu navegador conduz a navegação; o provedor corporativo atua como IdP; a plataforma de treinamento atua como SP ou RP. O produto não determina o papel sozinho: uma plataforma pode assumir papéis diferentes em integrações diferentes. [2][4]

A aplicação continua responsável por associar a identidade recebida à conta correta e decidir permissões. O IdP não conhece necessariamente todas as regras de negócio de cada serviço.

O navegador transporta; a aplicação valida

Receber uma mensagem pelo navegador não a torna confiável. O SP/RP deve verificar origem, integridade, destinatário, validade e vínculo com o fluxo esperado.

Microtarefa 3

Identifique usuário, navegador, IdP e SP/RP no acesso de um funcionário a um portal de benefícios. Quem deveria decidir se ele pode aprovar um benefício de outra pessoa?

04 | RELAÇÃO DE CONFIANÇA

Confiança, cadastro e metadados

Antes do primeiro login, as equipes estabelecem quais provedores e aplicações podem participar. A relação envolve responsáveis, finalidade, atributos compartilhados e parâmetros técnicos. Importar um arquivo ou descobrir uma URL não substitui verificar quem controla o emissor. [1]

Em SAML 2.0	Em OIDC
Metadados XML descrevem entityID, endpoints, certificados e capacidades. [3]	Discovery publica issuer, endpoints e jwks_uri, entre outros dados. [18]
O SP configura o IdP confiável, serviço de SSO e certificados para verificar assinaturas.	O RP configura o emissor esperado e obtém suas chaves públicas por uma origem confiável.
O IdP conhece o SP, seu identificador e a URL ACS que recebe respostas.	O cadastro do cliente define client_id e redirect_uris permitidas; clientes confidenciais têm autenticação própria.

Exemplo: o RH espera o emissor corporativo e respostas destinadas ao seu próprio identificador. Um certificado inserido por engano, um emissor diferente ou um endereço de retorno excessivamente amplo pode quebrar essa fronteira de confiança.

Como verificar a assinatura: na assinatura assimétrica, o emissor usa sua chave privada; o consumidor usa a chave pública confiável para verificar a integridade. A chave pública não permite produzir assinaturas válidas em nome do emissor.

Operação: mantenha inventário de integrações, proprietário, ambiente, identificadores, URLs e atributos. Planeje a rotação e a expiração de certificados e chaves, com testes; a chave privada permanece protegida com quem assina.

Microtarefa 4

Uma equipe recebe por mensagem um arquivo de metadados “atualizado”. Quais verificações de origem e aprovação faria antes de substituir a confiança do sistema de RH?

05 | VISÃO DE PONTA A PONTA

Fluxo simplificado de login federado

Neste fluxo, a pessoa começa pela aplicação. O desenho resume a lógica comum; o transporte e as mensagens mudam entre SAML e OIDC.

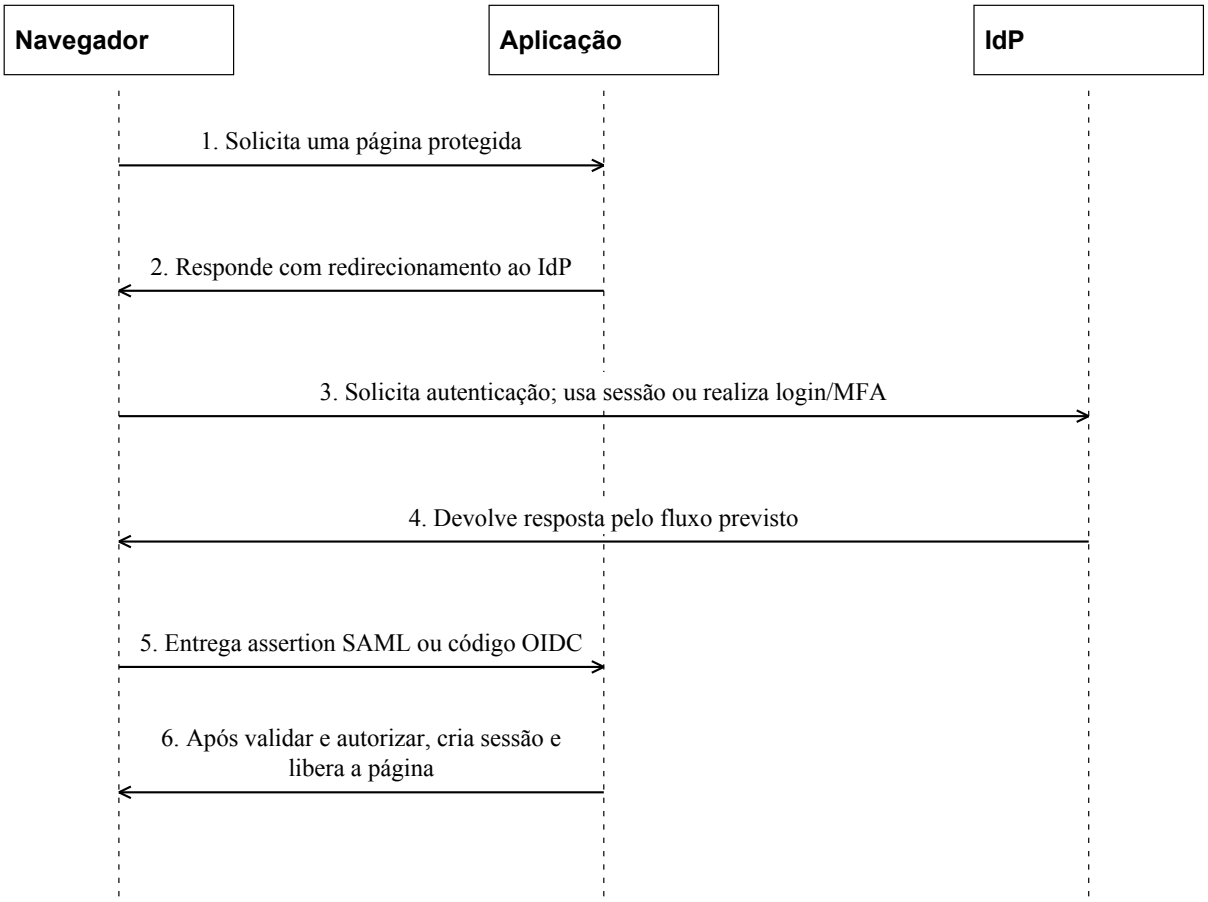


Figura 1. Fluxo didático iniciado na aplicação (SP/RP). Em OIDC, há uma troca adicional do código por tokens entre aplicação e IdP, detalhada na página 9.

Ao abrir um segundo serviço, a sessão do IdP pode dispensar nova digitação de credenciais. O segundo serviço ainda precisa executar seu fluxo, validar a resposta e verificar as permissões da pessoa.

Microtarefa 5

Marque no desenho onde ocorre autenticação, onde a aplicação toma uma decisão de autorização e onde a sessão do IdP poderia evitar uma nova tela de login.

06 | SAML 2.0

SAML: autenticação para serviços web

SAML 2.0 usa XML para representar assertions e mensagens de segurança. É comum em integrações de SSO corporativo entre um IdP e aplicações web. Neste estudo, usamos o perfil de SSO via navegador iniciado no SP. [2][19]

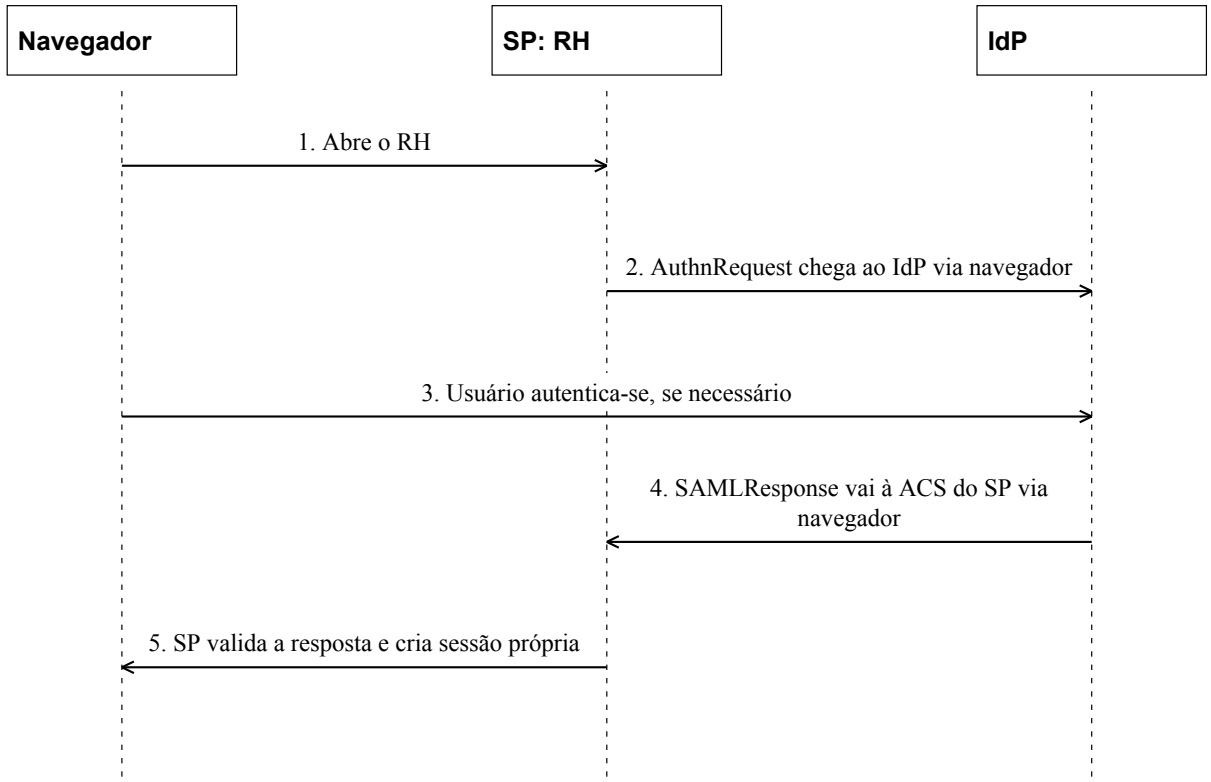


Figura 2. Setas entre SP e IdP representam mensagens transportadas pelo navegador neste exemplo, não uma conexão direta entre esses servidores.

O que observar: a assertion pode conter identificador do sujeito, contexto de autenticação, atributos, destinatário e restrições de tempo. A assinatura permite verificar a integridade e o emissor confiável; não torna o conteúdo automaticamente confidencial. [2]

O SP deve validar assinatura conforme o perfil, emissor, audience, destinatário/ACS, janelas de tempo e correlação com a solicitação; deve prevenir reutilização indevida. Bibliotecas mantidas reduzem riscos do processamento XML. [14]

Microtarefa 6

Uma assertion válida para o treinamento chega ao RH. Por que uma assinatura correta, sozinha, não basta para aceitar esse login?

07 | OPENID CONNECT

OIDC: identidade sobre OAuth 2.0

OpenID Connect (OIDC) acrescenta uma camada de identidade ao OAuth 2.0. O RP solicita o escopo **openid** e recebe um **ID token**, que informa sobre a autenticação da pessoa. No fluxo abaixo, o portal tem um servidor capaz de guardar suas credenciais de cliente. [4]

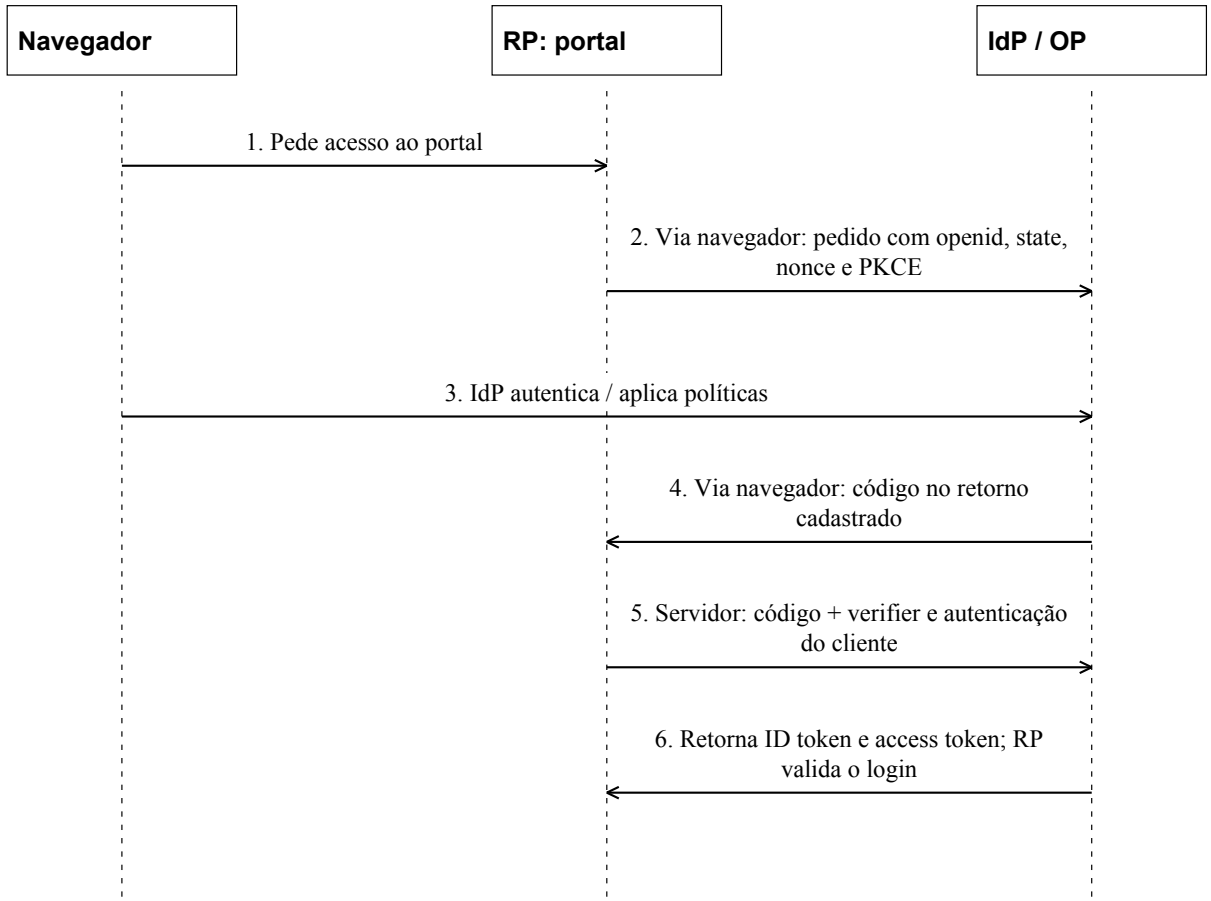


Figura 3. Passos 5 e 6 usam comunicação entre servidores neste exemplo. O portal cria sua sessão após validar a resposta e aplicar suas regras.

Proteções: redirect_uri limita o retorno; state vincula a resposta à navegação; nonce vincula o ID token ao pedido; PKCE vincula o código ao cliente que iniciou a transação. Usam-se valores específicos por transação e validação adequada. [7][20]

ID token serve ao RP para autenticação. Access token serve à API para acesso autorizado. Usar um como se fosse o outro causa erros de segurança. [4][6]

08 | OAUTH 2.0

Delegação de acesso a uma API

OAuth 2.0 é um framework de autorização. Ele permite conceder acesso limitado a recursos sem fornecer a senha da pessoa ao aplicativo que os utilizará. OAuth isolado não define uma prova padronizada de identidade para login; OIDC acrescenta essa camada. [5]

Exemplo: relatório de treinamentos

Uma ferramenta precisa consultar apenas a conclusão de cursos de Ana. Ela recebe permissão de leitura, representada por um escopo como **treinamentos.read** (nome fictício), e apresenta um access token à API. Isso não deve conceder alteração de notas nem acesso ao RH.

Papel OAuth	No exemplo
Resource owner	Ana, em um cenário de acesso delegado a seus recursos.
Client	Ferramenta de relatórios que solicita acesso.
Authorization server	Servidor que avalia a concessão e emite o token.
Resource server	API que verifica o token e aplica o acesso permitido.

O consentimento pode envolver a pessoa e/ou políticas e aprovação administrativa, conforme o ambiente. Escopos limitam o que o token pode solicitar; a API também verifica contexto, recurso e regras de negócio.

OAuth também permite acesso em nome do próprio aplicativo, como em integrações entre serviços. Nesse caso, não se presume a presença de um usuário nem uma sessão de SSO. [5]

Microtarefa 7

Classifique: entrar no portal; autorizar leitura de uma API; permitir aprovação de despesas. Identifique o conceito principal e explique quais decisões ainda cabem à aplicação.

09 | COMPARAÇÃO

SAML, OIDC e OAuth 2.0

Os três padrões podem aparecer na mesma organização. A escolha depende da finalidade e das capacidades dos sistemas, não apenas da idade do produto. [2][4][5]

Critério	SAML 2.0	OIDC	OAuth 2.0
Finalidade neste contexto	Federação e SSO web por assertions.	Autenticação federada e identidade sobre OAuth.	Delegação e controle de acesso a recursos/APIs.
Artefato central	Assertion em XML, em uma resposta SAML.	ID token; usa também artefatos OAuth.	Access token; pode haver refresh token.
Formato	XML.	ID token em JWT.	Access token pode ser opaco ou JWT.
Quem consome	SP valida a mensagem/assertion.	RP valida o ID token.	API valida o access token.
Exemplo	Entrar no RH integrado ao IdP.	Entrar em um portal web corporativo.	Permitir que um relatório leia uma API.
Atenção	Assinatura não substitui audience e destinatário.	ID token não é credencial de acesso genérica a APIs.	OAuth sozinho não é protocolo padronizado de login.

Não confunda: SAML e OIDC podem viabilizar SSO; OAuth pode participar de um fluxo OIDC, mas seu objetivo próprio é autorização. SAML também representa atributos e outras declarações; aqui estudamos sua aplicação em SSO.

Microtarefa 8

Um fornecedor diz “nosso login é OAuth, portanto a identidade já está validada”. Que pergunta você faria sobre OIDC, ID token e o emissor confiável?

10 | ARTEFATOS DE SEGURANÇA

Tokens, assertions e validação

Assertion é uma declaração sobre um sujeito; em SAML, usa XML. **Token** é um artefato usado em um fluxo de segurança. JWT é um formato de token com declarações chamadas *claims*; nem todo token é JWT. [2][8]

Verificação	Pergunta que o sistema deve responder
Assinatura e chave	A mensagem foi íntegra e emitida por uma origem confiável, usando algoritmo permitido e chave correta?
Emissor (issuer / iss)	É exatamente o provedor esperado para esta integração?
Sujeito (subject / sub)	A identidade está associada à conta correta, no contexto do emissor?
Destinatário (audience / aud)	Este artefato foi emitido para este consumidor? No ID token, o destinatário inclui o client_id do RP.
Tempo (exp, nbf ou condições)	O artefato está dentro da validade, considerando relógios sincronizados e tolerância controlada?
Fluxo e reutilização	A resposta corresponde ao pedido e não está sendo reutilizada indevidamente?

Assinatura não é criptografia. Um JWT assinado pode ter seu conteúdo lido por quem o obtiver. HTTPS protege o transporte; proteção do armazenamento e minimização de atributos também são necessárias. [6][8]

Três finalidades: ID token comprova autenticação ao RP; access token concede acesso limitado à API; refresh token, quando emitido, permite solicitar novos tokens e exige proteção especial. Não copie tokens reais em decodificadores públicos. [5][6]

Microtarefa 9

Um token tem assinatura correta e ainda não expirou, mas foi emitido para outra API. Qual verificação deve rejeitá-lo? Por quê?

11 | AMBIENTE CORPORATIVO

SSO em plataformas de identidade

Uma organização pode integrar aplicações internas e serviços em nuvem a um provedor corporativo. A pessoa usa a identidade gerenciada, enquanto cada aplicação mantém seu contexto de negócio. Os produtos abaixo ilustram possibilidades, não uma indicação de compra.

Plataforma	Exemplo conceitual de uso
Microsoft Entra ID	Um portal e aplicações corporativas usam a identidade central. Conditional Access avalia sinais para aplicar políticas de acesso, como exigir MFA ou bloquear condições definidas. [10]
Google Workspace	Contas gerenciadas podem acessar aplicações SAML que confiam no Google como IdP, mediante configuração dos identificadores, ACS, certificado e atributos. [11]
Okta	Pode atuar como provedor para aplicações e integrar provedores externos. Seu papel depende da relação de confiança estabelecida em cada integração. [12]

Como analisar uma integração

Pergunte: qual protocolo a aplicação suporta? Quem é o emissor? Como a conta é criada? Quais atributos são enviados? Como permissões, MFA e encerramento de sessão funcionam? Quem cuida da rotação de chaves e de incidentes?

Aplicações antigas podem exigir conectores ou adaptações. Um catálogo de aplicativos facilita a experiência, mas não garante que todos tenham federação, provisionamento ou logout integrado. Recursos variam conforme produto, edição e integração.

Microtarefa 10

Uma empresa possui um RH com SAML e um portal com OIDC. Explique como ambos poderiam utilizar o mesmo provedor corporativo e por que cada integração teria configuração própria.

12 | DEFESA EM CAMADAS

MFA, contexto e menor privilégio

MFA combina fatores de categorias diferentes: algo que você sabe, possui ou é. Duas senhas não representam dois fatores. Métodos resistentes a phishing, como chaves FIDO2 e passkeys adequadamente implementadas, reduzem ataques em que a pessoa autentica em um site falso. [17]

Acesso condicional usa contexto para determinar exigências de acesso: aplicação, grupo, dispositivo, localização e risco, conforme a solução. Conditional Access é o nome dessa capacidade no Microsoft Entra ID. Uma política pode exigir MFA e dispositivo gerenciado para o RH. [10]

Menor privilégio concede apenas os acessos necessários. SSO simplifica a autenticação; ele não exige que todos recebam o mesmo perfil. Separe contas administrativas das contas de uso diário e revise concessões conforme a função.

Situação fictícia	Política proposta para discutir
Colaborador consulta treinamento	Acesso atribuído ao grupo de colaboradores, com MFA conforme o contexto.
Gestor aprova uma ação sensível	Permissão específica e possível autenticação recente/adicional.
Administrador altera confiança do RH	Conta administrativa, autenticação forte, registro e revisão da mudança.

Uma sessão já aberta no aplicativo pode não receber de imediato uma nova decisão do IdP. Reautenticação, avaliação contínua e controles de sessão dependem do suporte de cada integração. [13]

Microtarefa 11

Proponha uma política para acessar dados de RH fora do escritório. Indique sinais usados, exigência de autenticação e permissões. Não suponha que localização, sozinha, comprova identidade.

13 | CONTAS E ATRIBUTOS

Provisionamento e introdução a SCIM

Provisionar é criar e manter contas e seus atributos. **Desprovisionar** é retirar o acesso quando ele deixa de ser necessário, desativando a conta ou removendo vínculos e permissões. A exclusão definitiva depende de regras de retenção e continuidade do negócio.

SCIM (System for Cross-domain Identity Management) padroniza operações para gerenciar recursos como usuários e grupos entre sistemas, normalmente com HTTP e JSON. Pode apoiar criação, atualização e desativação de usuários; não é um protocolo de login. [9]

Dois caminhos diferentes

Autenticação: pessoa/navegador → IdP → aplicação, pelo fluxo SAML ou OIDC.
Provisionamento: serviço autorizado de gestão de identidades → interface da aplicação, por SCIM ou outro conector. Nesse caminho, a pessoa não precisa estar fazendo login.

Uma aplicação pode criar o perfil no primeiro login, prática chamada de **Just-in-Time (JIT)**. Isso não resolve automaticamente o desligamento de alguém que já possui conta, sessão ou permissões locais. [12]

Cuidados: definir fonte oficial de atributos, usar identificadores estáveis, proteger a credencial do conector, limitar permissões e monitorar falhas e atrasos. Não presumir que a alteração de um grupo chegue imediatamente a todos os destinos.

Microtarefa 12

O SSO funciona, mas o conector SCIM está com erro há dois dias. Que problemas podem aparecer para uma pessoa recém-contratada e para uma pessoa desligada? Registre os impactos separadamente.

14 | CICLO DE VIDA

Admissão, mudança e desligamento

O acesso deve acompanhar a relação da pessoa com a empresa. O processo envolve RH, gestão, IAM e responsáveis pelos aplicativos. O quadro a seguir é uma proposta didática de coordenação, não uma política interna existente.

Evento	Ações e confirmação esperada
Admissão: Ana entra na empresa	RH registra o vínculo; IAM cria a identidade, atribui grupos aprovados e orienta o cadastro de MFA. Contas são provisionadas. Confirmar acesso ao próprio perfil no RH, portal e cursos previstos.
Mudança: Ana passa a gestora	Validar a nova função, remover direitos anteriores desnecessários e aprovar os novos. Conferir grupos e papéis em cada aplicação, sem acumular privilégios automaticamente.
Desligamento: termina o vínculo	No horário definido, bloquear novos logins, revogar sessões/tokens conforme suporte, desativar contas e remover acessos locais e delegações. Confirmar resultados em cada destino e preservar registros necessários.

Desligar no IdP é uma etapa; verificar a perda efetiva de acesso é outra. A aplicação pode manter cookies, chaves de API pessoais, logins locais ou sessões que exigem ação própria. Falhas de desprovisionamento precisam de responsável e tratamento. [13]

Cenário para resolver

Ana começa na segunda-feira às 9h e encerra o vínculo três meses depois, às 18h de uma sexta-feira. O treinamento sincroniza contas por lotes. Defina os responsáveis, a ordem das ações, uma medida para o intervalo até a sincronização e a evidência de encerramento.

Sua resposta deve distinguir acesso futuro, sessões existentes e dados que já tenham sido baixados. A retirada de acesso ao serviço não elimina cópias locais automaticamente.

15 | SESSÕES E LIMITES

Logout e revogação não são iguais

No SSO, há diferentes estados de acesso. Entender quem os controla evita concluir que um único botão encerrou tudo.

Estado	Quem controla / limite
Sessão do IdP	Mantida pelo provedor, em geral com cookie. Encerrá-la pode impedir o reaproveitamento do login central.
Sessão da aplicação	Mantida pelo SP/RP. Pode continuar válida após o logout do IdP, conforme a integração. [13]
Access token	Pode ser aceito até expirar se a API apenas valida o token localmente e não consulta revogação ou eventos.
Refresh token	Permite obter novos tokens quando ainda aceito. Revogá-lo não garante invalidar imediatamente todos os access tokens já emitidos. [21]

Logout local encerra a sessão de uma aplicação. **Logout federado** busca coordenar sessões entre participantes; SAML Single Logout e extensões OIDC, como RP-Initiated Logout, dependem de implementação e configuração compatíveis. [16][19]

Revogação retira a validade ou a aceitação de uma credencial/sessão antes de seu término normal. Introspection permite consultar o estado ativo de um token; sua eficácia operacional depende da frequência das consultas e de caches. [21][22]

Linha do tempo fictícia

10h00: token emitido, com expiração às 10h15.
10h05: conta bloqueada no IdP.
Se a API só valida assinatura e prazo, o token pode continuar aceito até 10h15. Se houver controle adicional compatível, o bloqueio pode ocorrer antes. Os horários não são padrões de nenhum produto.

Microtarefa 13

Por que trocar a senha, fechar o navegador ou sair do portal pode não encerrar todas as sessões? Proponha duas verificações para um desligamento urgente.

16 | AMEAÇAS E CONTROLES

Riscos em uma arquitetura federada

Risco	Consequência	Controles a considerar
Conta central comprometida	O invasor pode alcançar vários serviços atribuídos à identidade.	MFA resistente a phishing, menor privilégio, proteção de administradores e resposta a incidentes.
Confiança configurada incorretamente	Aplicação aceita emissor, chave, destinatário ou retorno indevido.	Revisar cadastro, restringir URLs, validar mensagens e testar rejeições.
Phishing e roubo de sessão	Uma tela falsa captura credenciais ou um intermediário rouba cookies.	Métodos resistentes a phishing, proteção do dispositivo e orientação de usuários. [17]
Tokens/assertions expostos	Artefatos copiados podem permitir acesso ou revelar atributos.	HTTPS, armazenamento protegido, validade adequada e ausência de segredos nos logs. [6]
IdP indisponível	Novos logins podem falhar; sessões existentes têm comportamento variável.	Monitorar disponibilidade, planejar continuidade e testar recuperação.
Contas órfãs e acessos antigos	Pessoa desligada ou transferida mantém direitos.	Desprovisionamento, reconciliação de contas e revisões de acesso.

Continuidade não deve depender de liberar o acesso de todos sem autenticação. Contas de emergência, quando necessárias, devem ser restritas, protegidas, monitoradas e testadas sob processo definido.

Microtarefa 14

Escolha dois riscos da tabela. Para cada um, descreva uma prevenção, uma evidência que permitiria detectar o problema e uma ação inicial de contenção.

17 | OPERAÇÃO E AUDITORIA

O que registrar e acompanhar

Logs do IdP, da aplicação, da API e do provisionamento respondem a perguntas diferentes. Correlacioná-los ajuda a descobrir se a falha ocorreu no login, na validação, na autorização ou no ciclo de vida da conta. [15]

Origem	Eventos e informações úteis
IdP	Sucesso/falha de autenticação, exigência e resultado de MFA, aplicação, política aplicada, horário e contexto permitido.
SP/RP e API	Aceitação/rejeição do fluxo, erro de validação, criação/encerramento de sessão e negação de uma operação.
Provisionamento	Criação, atualização, desativação, falha do conector, horário da última execução e confirmação no destino.
Administração	Mudanças de chaves, metadados, URLs, atributos, grupos, papéis e políticas de confiança.

Use identificadores de evento/correlação, identidade e aplicação, com horários sincronizados e fuso explícito. Restrinja acesso aos registros, proteja sua integridade e defina retenção conforme os requisitos da organização.

Não registrar: senhas, cookies de sessão, tokens completos, chaves privadas e atributos pessoais desnecessários. Os dados necessários à investigação devem ser minimizados e protegidos. [15]

Boas práticas de implantação

Mantenha inventário e responsáveis; use bibliotecas atualizadas; teste em ambiente de homologação; valide fluxos de sucesso e rejeição; prepare rotação de chaves e recuperação. Para OIDC/OAuth, prefira Authorization Code com PKCE e evite fluxos legados que exponham tokens ou recolham a senha do usuário no cliente. [7]

Microtarefa 15

O IdP registra login bem-sucedido, mas o RH nega acesso. Quais registros você consultaria a seguir? Como distinguiria falha de validação de falta de permissão?

18 | ESTUDO DE CASO

Desenhe a arquitetura federada

A empresa fictícia **Horizonte Saúde** possui 320 funcionários. Há três logins independentes: portal interno, sistema de RH e plataforma de treinamento. A equipe quer SSO, MFA e retirada de acesso coordenada no desligamento.

Sistema	Condições informadas para o exercício
Portal interno	Aplicação web com servidor; aceita OIDC e possui perfis colaborador/gestor.
RH	Serviço web que aceita SAML 2.0 e SCIM. Colaboradores veem seus dados; RH tem permissões adicionais.
Treinamento	Aceita SAML 2.0 ou OIDC. Não possui SCIM; um administrador consegue desativar contas e encerrar sessões.

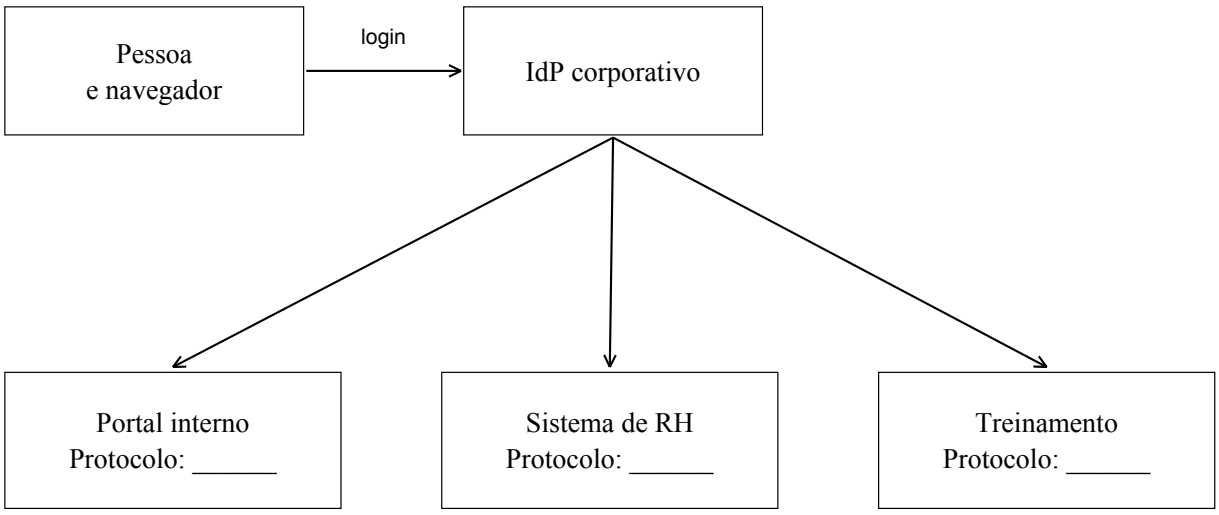


Figura 4. Esboço para completar. Setas de confiança não representam todos os saltos de rede. Redesenhe com fluxos de login e de ciclo de vida separados.

Entrega: um desenho com pessoa/navegador, IdP, três SPs/RPs e protocolos. Inclua fonte oficial dos vínculos, caminho de provisionamento, grupos/perfis, MFA, registros e responsável por cada aplicativo. Justifique a escolha de protocolo e o tratamento do treinamento sem SCIM.

Não é necessário contratar serviços nem acessar dados reais. É permitido escolher um IdP conceitual; capacidades não informadas devem ser declaradas como hipóteses.

19 | ANÁLISE DO CASO

Investigue e acompanhe o acesso

Situação A: admissão e função

Bruno entra como analista. Ele precisa acessar os três sistemas, consultar apenas seus dados no RH e realizar os cursos obrigatórios. Após dois meses, torna-se gestor. Descreva a criação inicial da identidade, o cadastro de MFA, o provisionamento de cada conta e as alterações de permissão. Explique como evitar o acúmulo de direitos.

Situação B: desligamento com sessão aberta

O vínculo de Bruno termina às 18h. A conta central é bloqueada nesse horário. O treinamento permanece aberto em um computador, e o responsável ainda não executou a desativação local. Determine quais ações e confirmações faltam antes de encerrar o atendimento.

Horário fictício (UTC-3)	Evidência fornecida
17h50	IdP: autenticação de Bruno no treinamento aprovada.
18h00	IAM: identidade central desativada com sucesso.
18h02	RH: conector SCIM confirma usuário inativo.
18h08	Treinamento: requisição aceita com sessão criada antes das 18h.

Perguntas de investigação:

1. Há evidência suficiente para afirmar que ocorreu um novo login às 18h08?
2. Qual participante controla a sessão observada?
3. Que ação pode conter o acesso e que registro confirma sua execução?
4. Como o processo de desligamento deve tratar o treinamento sem SCIM?

Registro do grupo

Produza uma tabela com etapa, responsável, horário esperado, evidência e pendência. Separe o que os registros demonstram das hipóteses que ainda precisam de verificação.

20 | DESAFIO FINAL

Proposta de IAM para a Horizonte Saúde

Consolide o estudo de caso em uma proposta de **2 a 4 páginas, incluindo o desenho**. O objetivo é explicar as decisões de forma que a equipe de operações consiga revisar o plano. Use linguagem clara e hipóteses explícitas.

Sua proposta deve conter

1. **Arquitetura:** IdP, navegador, SP/RP e protocolos por sistema.
2. **Fluxo:** primeiro login e entrada no segundo aplicativo com sessão existente, incluindo validações.
3. **Permissões:** perfis colaborador, gestor e RH; menor privilégio e MFA/contexto.
4. **Ciclo de vida:** admissão, mudança e desligamento, com SCIM onde disponível e procedimento para o treinamento.
5. **Resposta:** conta central comprometida, token exposto e IdP indisponível.
6. **Verificação:** evidências para confirmar acesso permitido, negação e revogação efetiva.

Critérios de avaliação propostos

Critério	Evidência esperada	Pontos
Clareza conceitual	Distingue autenticação, autorização, federação e SSO.	2
Arquitetura e protocolo	Papéis e fluxos coerentes; escolha justificada.	2
Segurança	Validações, MFA, privilégios e riscos tratados.	2
Ciclo de vida e sessões	Contempla os três eventos e os limites da revogação.	2
Operação e evidências	Define responsáveis, logs e verificações observáveis.	2

Teste de coerência: explique a um colega por que conseguir entrar em um sistema não prova que você pode acessar todos os dados dele. Depois, peça que ele encontre uma sessão ou conta que seu plano de desligamento ainda não tratou.

21 | EXERCÍCIOS

Pratique a distinção entre os conceitos

Responda no caderno ou em um documento. Justifique as escolhas; não há gabarito neste material.

1. Associe cada situação ao conceito principal

a) Verificar uma passkey antes de entrar no portal.
b) Decidir se alguém pode aprovar uma solicitação de RH.
c) Aceitar a autenticação emitida por um IdP confiável.
d) Abrir outra aplicação sem repetir a autenticação completa.
Use: autenticação, autorização, federação e SSO.

2. Verdadeiro ou falso? Corrija as falsas

a) Usar o mesmo e-mail e senha em dois sites comprova SSO.
b) OAuth 2.0, isoladamente, define um protocolo de login de usuário equivalente ao OIDC.
c) Um ID token pode substituir qualquer access token em uma API.
d) Uma conta federada pode ter registro e permissões na aplicação.
e) SCIM é usado para gerenciar usuários e grupos entre sistemas.
f) O logout do IdP sempre encerra todas as sessões das aplicações.

3. Escolha e justifique

a) Um portal quer autenticar uma pessoa usando OIDC. Qual artefato o RP valida para essa finalidade: ID token ou access token?
b) Uma integração quer ler uma API em nome de um usuário. Qual framework trata a delegação: OAuth 2.0 ou SCIM?
c) Uma aplicação já aceita apenas SAML. Qual informação adicional você precisa antes de propor uma integração?

4. Analise uma validação

O RH recebe uma assertion ainda válida, assinada por um IdP conhecido, cuja audience identifica o treinamento. Explique a decisão esperada e por que os outros controles não eliminam essa verificação.

5. Planeje a auditoria

Liste quatro eventos que ajudariam a investigar uma conta central comprometida e três tipos de informação sensível que não devem aparecer integralmente nos logs.

22 | AUTOAVALIAÇÃO SEM GABARITO

Verifique sua aprendizagem

Para cada afirmação, marque **0 = ainda não consigo**, **1 = consigo com consulta** ou **2 = consigo explicar com exemplo**. Use o resultado para escolher o que revisar; não é uma nota de certificação.

Consigo...	**0**	**1**	**2**
Diferenciar autenticação e autorização.			
Explicar identidade local e identidade federada.			
Distinguir SSO de repetir a mesma senha.			
Identificar IdP, SP/RP, usuário e navegador.			
Explicar confiança, metadados e destinatário.			
Descrever um login SAML e um login OIDC.			
Diferenciar OAuth, OIDC e SAML.			
Distinguir ID token, access token e refresh token.			
Explicar MFA, contexto e menor privilégio.			
Distinguir SCIM de login e tratar desligamentos.			
Explicar limites de logout e revogação.			
Propor registros e controles para dois riscos.			

Reflexão 1: qual confusão conceitual você corrigiu durante a leitura? Escreva sua explicação usando um exemplo novo.

Reflexão 2: escolha um item marcado com 0 ou 1. Registre a página que vai revisar e uma pequena ação para demonstrar que aprendeu.

23 | CONSULTA RÁPIDA

Glossário e roteiro de revisão

Termo	Significado no contexto da aula
ACS	Assertion Consumer Service: endpoint do SP que recebe respostas SAML.
Assertion / claim	Declaração sobre identidade ou contexto; claim é um campo declarativo, como issuer ou subject.
Audience	Consumidor a que o artefato se destina; precisa ser verificado.
Autenticador	Meio usado para demonstrar controle de uma identidade, como uma chave de segurança.
Cookie de sessão	Artefato do navegador usado para manter a sessão com um domínio.
IdP / OP	Provedor de identidade; OP é o OpenID Provider no OIDC.
Issuer / subject	Emissor / identificador do sujeito no contexto do emissor.
JWT / JWKS	Formato de token com claims / conjunto de chaves em JSON. O JWKS público permite obter chaves para verificação.
MFA / PKCE	Autenticação com múltiplos fatores / proteção que vincula o código ao cliente que iniciou o fluxo.
Redirect URI	Endereço de retorno cadastrado no fluxo OAuth/OIDC.
SCIM / scope	Protocolo de gestão de identidades / limite de acesso solicitado ou concedido em OAuth.
SP / RP	Aplicação que confia na autenticação externa: Service Provider / Relying Party.

Roteiro de revisão em seis perguntas

Quem autentica? Quem autoriza? Em quem a aplicação confia? Qual mensagem é validada e para quem foi emitida? Como as contas são criadas e removidas? O que acontece com sessões existentes quando o vínculo termina?

As respostas devem considerar separadamente identidade, permissões e estados de sessão. Use as referências seguintes para aprofundar os pontos que ainda geram dúvida.

24 | REFERÊNCIAS

Fontes e aprofundamento - 1/2

Fontes primárias e documentação oficial. Links consultados em 22 de outubro de 2026. As aplicações em exercícios e os cenários são construções didáticas.

[1] NIST. Digital Identity Guidelines: Federation and Assertions. SP 800-63C-4, 2025.
https://pages.nist.gov/800-63-4/sp800-63c.html
Fundamentos de federação, confiança e assertions.

[2] OASIS. Assertions and Protocols for SAML V2.0. Standard, 2005.
https://docs.oasis-open.org/security/saml/v2.0/saml-core-2.0-os.pdf
Declarações e protocolos SAML.

[3] OASIS. Metadata for SAML V2.0. Standard, 2005.
https://docs.oasis-open.org/security/saml/v2.0/saml-metadata-2.0-os.pdf
Identificadores, endpoints e material de confiança.

[4] OPENID FOUNDATION. OpenID Connect Core 1.0, incorporating errata set 2, 2023.
https://openid.net/specs/openid-connect-core-1_0.html
Autenticação, ID token e validações.

[5] IETF. The OAuth 2.0 Authorization Framework. RFC 6749, 2012.
https://www.rfc-editor.org/rfc/rfc6749.html
Papéis e concessão de acesso; ler com a atualização [7].

[6] IETF. OAuth 2.0: Bearer Token Usage. RFC 6750, 2012.
https://www.rfc-editor.org/rfc/rfc6750.html
Uso e proteção de bearer access tokens.

[7] IETF. Best Current Practice for OAuth 2.0 Security. RFC 9700, 2025.
https://www.rfc-editor.org/rfc/rfc9700.html
Práticas atuais, redirecionamentos e segurança dos fluxos.

[8] IETF. JSON Web Token (JWT). RFC 7519, 2015.
https://www.rfc-editor.org/rfc/rfc7519.html
Formato e claims de tokens JWT.

[9] IETF. SCIM: Protocol. RFC 7644, 2015.
https://www.rfc-editor.org/rfc/rfc7644.html
Operações de gestão de recursos de identidade.

[10] MICROSOFT LEARN. What is Conditional Access? Documentação técnica.
https://learn.microsoft.com/en-us/entra/identity/conditional-access/overview
Sinais e políticas de acesso no Entra ID.

[11] GOOGLE WORKSPACE HELP. Set up your own custom SAML app. Documentação técnica.
https://knowledge.workspace.google.com/admin/apps/set-up-your-own-custom-saml-app
SSO SAML usando Google como IdP.

24 | REFERÊNCIAS

Fontes e aprofundamento - 2/2

[12] OKTA DEVELOPER. External Identity Providers. Documentação técnica.
https://developer.okta.com/docs/concepts/identity-providers/
Papéis, integrações e criação JIT de usuários.

[13] MICROSOFT LEARN. Revoke user access in Microsoft Entra ID. Documentação técnica.
https://learn.microsoft.com/en-us/entra/identity/users/users-revoke-access
Limites das sessões e retirada efetiva de acesso.

[14] OWASP. SAML Security Cheat Sheet.
https://cheatsheetseries.owasp.org/cheatsheets/SAML_Security_Cheat_Sheet.html
Cuidados de validação e ameaças a SAML.

[15] OWASP. Logging Cheat Sheet.
https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html
Eventos, proteção de logs e exclusão de dados sensíveis.

[16] OPENID FOUNDATION. OpenID Connect RP-Initiated Logout 1.0, 2022.
https://openid.net/specs/openid-connect-rpinitiated-1_0.html
Solicitação de logout do RP ao provedor.

[17] NIST. Digital Identity Guidelines: Authentication and Authenticator Management. SP 800-63B-4, 2025.
https://pages.nist.gov/800-63-4/sp800-63b.html
Fatores, autenticadores e resistência a phishing.

[18] OPENID FOUNDATION. OpenID Connect Discovery 1.0, incorporating errata set 2, 2023.
https://openid.net/specs/openid-connect-discovery-1_0.html
Descoberta de endpoints e chaves do provedor.

[19] OASIS. Profiles for SAML V2.0. Standard, 2005.
https://docs.oasis-open.org/security/saml/v2.0/saml-profiles-2.0-os.pdf
Perfil Web Browser SSO e Single Logout.

[20] IETF. Proof Key for Code Exchange by OAuth Public Clients. RFC 7636, 2015.
https://www.rfc-editor.org/rfc/rfc7636.html
Mecanismo PKCE; ler com a atualização [7].

[21] IETF. OAuth 2.0 Token Revocation. RFC 7009, 2013.
https://www.rfc-editor.org/rfc/rfc7009.html
Revogação de tokens e efeitos sobre concessões.

[22] IETF. OAuth 2.0 Token Introspection. RFC 7662, 2015.
https://www.rfc-editor.org/rfc/rfc7662.html
Consulta ao estado ativo de um token.

Por onde continuar: comece por [1] para confiança, [4] para OIDC, [7] para práticas atuais e [13] para retirada de acesso. Especificações de 2005 e 2012 continuam úteis para a base dos protocolos, mas devem ser lidas com erratas, orientações de segurança e documentação atual da implementação.